



بنك الأفاق
AL-AFAQ BANK

صلاية استثمارية ... وأفاق عالمية | Global Horizon Banking

سياق ومتطلبات ونطاق أمن المعلومات

(Information Security Context, Requirements and Scope)

بنك الأفاق الرقمية — نظام إدارة أمن المعلومات وفق المواصفة القياسية الدولية ISO/IEC 27001:2022

تصنيف الوثيقة	سري (Confidential)
مرجع الوثيقة	ISMS-DOC-04-1
الإصدار	1.0
تاريخ الوثيقة	10 سبتمبر 2026 م
معدو الوثيقة (الفريق الاستشاري)	فهد العتيبي
مالك الوثيقة	أ. سارة الحربي (مدير أمن المعلومات - CISO)

سجل المراجعات (Revision History)

الإصدار	التاريخ	المؤلف / المراجع	ملخص التعديلات
1.0	10-09-2026	محمد العامري والفريق الاستشاري	الإصدار الأساسي الأول: تحديد شامل لسياق البنك، واحتياجات الأطراف المعنية، والنطاق التنظيمي والتفني للـ ISMS لبنك الآفاق الرقمية.

قائمة التوزيع (Distribution)

الاسم	المنصب / المسمى الوظيفي
د. نورة القحطاني	الرئيس التنفيذي (CEO)
م. فهد العتيبي	مدير تقنية المعلومات (CIO)
أ. سارة الحربي	مدير أمن المعلومات (CISO)
أ. ليلى الدوسري	مدير إدارة الشؤون القانونية
أ. أحمد الغامدي	مدير إدارة المراجعة الداخلية
أ. خالد الشمري	مدير إدارة الموارد البشرية

الاعتماد والمصادقة (Approval)

الاسم	المنصب	حالة الاعتماد	التاريخ
د. نورة القحطاني	الرئيس التنفيذي	معتمد (تنفيذياً)	10-09-2026
أ. سارة الحربي	مدير أمن المعلومات	تمت المراجعة والتحقق (تقنياً)	10-09-2026
أ. عبدالله المحيسن	رئيس مجلس الإدارة	مصادق عليه (مجلس الإدارة)	10-09-2026

المحتويات (Contents)

1	المقدمة.....	9
2	سياق المنظمة.....	10
2.1	الأنشطة.....	10
2.2	الوظائف.....	10
2.3	المنتجات والخدمات.....	11
2.4	سلاسل التوريد.....	12
3	القضايا الداخلية والخارجية.....	13
3.1	القضايا الداخلية.....	13
3.2	القضايا الخارجية.....	13
3.3	مستوى تقبل المخاطر (شهية المخاطر).....	14
4	الأطراف المعنية ومتطلباتها.....	16
4.1	الأطراف المعنية.....	16
4.2	المتطلبات.....	17
5	الغرض من نظام إدارة أمن المعلومات ونطاق.....	18
5.1	الغرض.....	18
5.2	الأثر المحتمل لحادث أمن المعلومات.....	18
5.3	أهداف أمن المعلومات.....	18
5.4	نطاق نظام إدارة أمن المعلومات.....	19
5.4.1	التنظيمي.....	19
5.4.2	المنتجات والخدمات.....	19
5.4.3	الأنشطة.....	20
5.4.4	الاستثناءات.....	20

1. المقدمة

تلتزم بنك الآفاق الرقمية بحماية أمن معلومات أعمالها في مواجهة الحوادث والوقائع غير المرغوب فيها، وقد قامت بتطبيق نظام إدارة أمن المعلومات (ISMS) المتوافق مع معيار ISO/IEC 27001 ، المعيار الدولي لأمن المعلومات.

يهدف هذا المستند إلى وصف آلية سير أعمال المنظمة، والعوامل الداخلية والخارجية المؤثرة عليها، بالإضافة إلى تسليط الضوء بصورة عامة على العواقب المحتملة لحدوث أي خرق أمني. سيتيح ذلك تطبيق المزيج الأنسب من التدابير والضوابط الرقابية لتقليل مستوى المخاطر، وضمان توفر خطط مختبرة لإدارة آثار أي انقطاعات قد تحدث في الأعمال.

وعلى وجه التحديد، يحدد هذا المستند ما يلي:

- سياق المنظمة.
 - القضايا الخارجية والداخلية ذات الصلة بغرض وأهداف بنك الآفاق الرقمية.
 - الأطراف المعنية ذات الصلة بنظام إدارة أمن المعلومات (ISMS).
 - متطلبات أمن المعلومات الخاصة بتلك الأطراف المعنية.
 - نطاق نظام إدارة أمن المعلومات، بما في ذلك حدوده وقابليته للتطبيق.
- سيتم تحديث هذا المستند سنوياً على الأقل، أو عند حدوث تغييرات جوهرية في المجالات ذات الصلة التي يتناولها.

2. سياق المنظمة (Organizational context)

يتم توضيح السياق التنظيمي لبنك الآفاق الرقمية في الأقسام التالية. ونظراً للطبيعة المتسارعة لقطاع الأعمال والأسواق التي تنشط فيها المنظمة، فإن هذا السياق عرضة للتغير بمرور الوقت؛ لذا ستتم مراجعة هذا المستند بصفة سنوية وتضمن أي تغييرات جوهرية تطرأ عليه، كما سيتم تحديث نظام إدارة أمن المعلومات (ISMS) لمواكبة آثار وتبعات هذه التغييرات..

2.1 الأنشطة (Activities)

تمارس بنك الآفاق الرقمية مجموعة واسعة من الأنشطة التجارية ضمن قطاعاتها المستهدفة، وتعمل باستمرار على تطوير منتجات وخدمات جديدة لطرحها في السوق.

- الخدمات المصرفية للأفراد (Retail): الحسابات الجارية والتوفير، التمويل الشخصي، البطاقات الائتمانية وبطاقات مدى، والتحويلات المحلية عبر "سريع" ونظام "سداد".
- الخدمات المصرفية للشركات (Corporate): التسهيلات الائتمانية للشركات، خطابات الضمان، والاعتمادات المستندية، وإدارة السيولة وحلول الرواتب المؤسسية.
- الخزينة والاستثمار والعمليات الدولية: إدارة المحافظ الاستثمارية للبنك، تداول العملات الأجنبية، وأدوات التحوط، والتحويلات الدولية عبر شبكة سويفت (SWIFT).
- القنوات المصرفية الرقمية: تطبيق الهاتف المحمول "آفاق بلس"، منصة الخدمات الإلكترونية عبر الإنترنت "آفاق نت"، والربط مع المنصات الوطنية.
- قاعدة العملاء: يخدم البنك أكثر من 500,000 عميل نشط من الأفراد والشركات في مختلف مناطق المملكة.
- الانتشار الجغرافي: المقر الرئيسي بالرياض (حي المال والأعمال)؛ مركز البيانات الرئيسي بالطابق الثالث؛ مركز التعافي من الكوارث بجدة؛ 25 فرعاً مصرفياً (10 الرياض، 8 جدة، 7 المنطقة الشرقية)؛ و75 جهاز صراف آلي مستقل.
- الميزانية والوضع المالي: يتمتع البنك بمركز مالي قوي؛ تبلغ الميزانية السنوية المخصصة لأمن المعلومات حالياً 12 مليون ريال سعودي، مع اعتماد زيادتها إلى 18 مليون ريال فور اكتمال تطبيق الـ ISMS.

2.2 الوظائف (Functions)

تتألف بنك الآفاق الرقمية من الوظائف التنظيمية التالية:

- الإدارة العليا: مجلس الإدارة برئاسة السيد عبدالله المحيسن، والرئيس التنفيذي الدكتورة نورة القحطاني، ومكتب الرئيس التنفيذي.
- قطاع الأعمال والمخاطر: إدارة المخاطر المؤسسية، إدارة الالتزام والحوكمة، إدارة الشؤون القانونية (برئاسة الأستاذة ليلي الدوسري)، وإدارة المراجعة الداخلية (برئاسة الأستاذ أحمد الغامدي).
- قطاع التقنية والعمليات: إدارة تقنية المعلومات (برئاسة المهندس فهد العتيبي: البنية التحتية، التطبيقات، التطوير مع 25 مطوراً، قواعد البيانات، والدعم الفني)، وإدارة أمن المعلومات (برئاسة الأستاذة سارة الحربي - CISO: الحوكمة، الـ SOC على مدار 7/24 مع 8 محللين، الاستجابة للحوادث مع 3 أخصائيين، وتقييم المخاطر والثغرات مع أخصائيين اثنين)، وإدارة العمليات المصرفية.
- قطاع الأعمال المصرفية: الخدمات المصرفية للأفراد، الخدمات المصرفية للشركات، الخزينة والاستثمار، العمليات الدولية، وإدارة التسويق وتجربة العميل.
- قطاع الموارد البشرية والشؤون الإدارية: إدارة الموارد البشرية (برئاسة الأستاذ خالد الشمري: التوظيف، التدريب، وشؤون الموظفين)، إدارة المرافق والخدمات، وإدارة المشتريات والعقود.
- قطاع المالية: الإدارة المالية، إدارة المحاسبة، وإدارة الرواتب والمزايا.

2.3 المنتجات والخدمات (Products and services)

تقدم بنك الآفاق الرقمية المنتجات والخدمات الرئيسية التالية لعملائها:

- تطبيق الهاتف المحمول "آفاق بلس": التطبيق المصرفي المطور لمنصتي iOS و Android، يتيح التحويلات الفورية، وإدارة البطاقات، ودفع الفواتير. تم تطويره داخلياً بمشاركة شركة برمجية خارجية متخصصة.
- منصة "آفاق نت" للخدمات المصرفية عبر الإنترنت: البوابة المصرفية عبر المتصفح للأفراد والشركات الكبرى لإدارة الحسابات والسيولة وإصدار التحويلات الجماعية للرواتب.
- نظام المعاملات المصرفية الأساسي (Core Banking System): العمود الفقري لعمليات البنك لإدارة الحسابات، والودائع، والقروض، والعملاء، وسجلات الأستاذ العام.
- نظام إدارة البطاقات (Card Management System): إصدار وتفعيل ومراقبة بطاقات الصراف الآلي والبطاقات الائتمانية ومعالجة العمليات ومكافحة الاحتيال.
- نظام الدفعات الفورية (Instant Payments System): الربط المباشر مع نظام المدفوعات الفورية الوطني (سريع) لمعالجة التسويات اللحظية على مدار الساعة.
- أنظمة الخزينة والتحويلات الدولية: بوابات سويفت للتحويلات المالية الخارجية والتداول بين البنوك.
- حساسية البيانات الشخصية (PII): بالغة الأهمية؛ يعالج البنك ويحفظ بيانات الهوية الوطنية/الإقامة، البصمات البيومترية، كشوفات الحسابات، الأرصدة، وعناوين وبيانات الاتصال لأكثر من 500,000 عميل و2,500 موظف.

2.4 سلاسل التوريد (Supply chains)

من أجل تقديم منتجاتنا وخدماتنا لعملائنا، تم اعتماد عدد من مسارات سلاسل التوريد الهامة. وتتمثل المسارات الرئيسية فيما يلي:

- مزود الخدمات السحابية (Amazon Web Services - AWS): استضافة بيانات التطوير، والاختبار، ومنصات تحليل البيانات الضخمة؛ تتطلب حوكمة سحابية وتحديداً دقيقاً للمسؤوليات المشتركة.
- مزود الاتصالات والإنترنت الرئيسي (شركة الاتصالات السعودية - STC): تقديم خطوط الألياف البصرية المزدوجة والمؤمنة للربط بين المقر الرئيسي بالرياض، وموقع التعافي بجدة، وكافة الفروع.
- شريك تطوير تطبيقات الهاتف المحمول: شركة برمجيات متعاقدة لتطوير ودعم واجهات برمجية لتطبيق "آفاق بلس"؛ تخضع لضوابط التطوير الآمن واتفاقيات عدم الإفصاح.
- شركة إدارة وصيانة أجهزة الصراف الآلي: الصيانة الوقائية والطارئة وتحديث أنظمة التشغيل والترقيع الأمني لأجهزة الصراف الآلي البالغ عددها 150 جهازاً.
- شركة خدمات النقد والحراسات الأمنية: شركة أمنية مرخصة مسؤولة عن نقل الأموال وتغذية أجهزة الصراف الآلي والخزائن الفرعية.
- استشاري فحص الثغرات والأمن السيبراني الخارجي: شركة استشارية أمنية معتمدة تنفذ الفحص الدوري للثغرات واختبارات الاختراق الربع سنوية.

3. القضايا الداخلية والخارجية (Internal and external issues)

هناك عدد من القضايا الداخلية والخارجية ذات الصلة بغرض وأهداف بنك الآفاق الرقمية والتي تؤثر على قدرة نظام إدارة أمن المعلومات (ISMS) على تحقيق النتائج المرجوة منه.

3.1 القضايا الداخلية (Internal issues)

فيما يتعلق بأعمال بنك الآفاق الرقمية ذاتها، هناك عدد من القضايا الداخلية ذات الصلة. وتشمل ما يلي:

- الثقافة التنظيمية: وجود مقاومة لدى بعض الموظفين القدامى الذين يرون إجراءات الأمن عائقاً أمام سرعة العمل؛ ثقافة "الأمن أولاً" تتطلب تعزيزاً مستمراً بدعم الإدارة العليا.
- دوران الكوادر التقنية: يبلغ معدل دوران الموظفين في تقنية المعلومات 12% سنوياً، مما يفرض تحدياً في الحفاظ على المعرفة المؤسسية ويستوجب إجراءات صارمة لإلغاء الصلاحيات فور انتهاء الخدمة.
- التنوع اللغوي والثقافي: تنوع الموظفين (2,500 موظف من السعوديين والوافدين) يفرض توفير برامج توعوية أمنية متعددة اللغات (العربية والإنجليزية).
- الأنظمة الموروثة القديمة: الاعتماد على نظام قديم لإدارة الرواتب ("سبيبرولا") غير مدعوم تقنياً ويشكل خطراً تشغيلياً حتى يتم استبداله.
- غياب نظام إدارة الهويات المميزة: إدارة كلمات مرور المسؤولين تتم يدوياً دون وجود نظام مركزي لإدارة الوصول المميز (PAM).
- غياب التحليل الآلي للسجلات: لا يوجد نظام مركزي لإدارة الأحداث الأمنية (SIEM)؛ ويتم تحليل السجلات بشكل يدوي مما يؤخر اكتشاف التهديدات.
- عدم مزامنة التوقيت في الشبكة: غياب خادم مركزي لبروتوكول NTP؛ تسبب وجود فارق زمني قدره 7 دقائق بين سجلات الجدار الناري والخوادم في إعاقة التحقيق الجنائي الرقمي سابقاً.
- الدروس المستفادة من الحوادث السابقة: أظهرت الحوادث السابقة (انقطاع الخدمات الرقمية لـ 3 ساعات بسبب خطأ في إعدادات الجدار الناري؛ محاولة التصيد المالي لتحويل 150,000 ريال في الإدارة المالية؛ فقدان لابتوب مدير التسويق غير المشفر الحاوي لبيانات العملاء؛ انتهاء صلاحية شهادة SSL وتوقف الموقع 4 ساعات؛ ووجود صلاحيات غير مسحوبة لموظفي IT على مجلدات رواتب وتقييمات HR وجود فجوات حادة في إدارة التغيير، التشفير، إدارة الشهادات، والمراجعة الدورية للصلاحيات.

سيتم النظر في هذه القضايا الداخلية العامة بمزيد من التفصيل كجزء من عملية تقييم المخاطر.

3.2 القضايا الخارجية (External issues)

فيما يتعلق بالبيئة الخارجية التي تعمل فيها بنك الآفاق الرقمية، هناك عدد من القضايا الخارجية ذات الصلة، وتشمل ما يلي:

- سياسياً وتنظيمياً (Political): بيئة سياسية مستقرة تدعم التحول الرقمي، مع أطر تشريعية وطنية مشددة بإشراف البنك المركزي والهيئة الوطنية للأمن السيبراني.
- اقتصادياً (Economic): منافسة شرسة مع البنوك التقليدية والرقمية الجديدة (Neobanks)؛ الثقة في أمن المعلومات تمثل العامل الأساسي للاحتفاظ بالعملاء، مع توفر ميزانية معتمدة بـ 18 مليون ريال.
- اجتماعياً (Social): مجتمع يعتمد كلياً على التعاملات المصرفية الرقمية الذكية على مدار 7/24؛ مع حساسية بالغة لأي تسريب للبيانات الشخصية عبر شبكات التواصل.
- تكنولوجياً (Technological): تصاعد التهديدات السيبرانية الموجهة للقطاع المالي (هجمات الفدية، التصيد المالي الموجه، هجمات حجب الخدمة DDoS، واستهداف سلاسل التوريد).
- قانونياً وتشريعياً (Legal): إلزامية الامتثال الصارم لضوابط البنك المركزي السعودي (ساما)، ونظام حماية البيانات الشخصية الصادر عن (سدأيا)، ونظام مكافحة الجرائم المعلوماتية، مع عقوبات مالية وتنظيمية قاسية للمخالفين.

- بيئياً وجغرافياً (Environmental): توفر مسافة 950 كم بين مركز البيانات الرئيسي بالرياض ومركز التعافي بجدة يوفر عزلاً جغرافياً متميزاً ضد الكوارث الطبيعية والمخاطر البيئية.

سيتم النظر في هذه القضايا الخارجية العامة بمزيد من التفصيل كجزء من عملية تقييم المخاطر..

3.3 الشهية للمخاطر وعتبات القبول (Risk Appetite)

يتبنى مجلس إدارة بنك الآفاق الرقمية شهية مخاطر عامة مصنفة بأنها 'منخفضة (Low)' في كل ما يخص أمن المعلومات والعمليات المصرفية.

تطبق الإدارة العليا سياسة 'عدم التسامح التام (Zero Tolerance)' حيال:

- سرية بيانات العملاء: أي خرق أو تسريب أو كشف غير مصرح به للبيانات المالية والشخصية للعملاء (PII).
- عدم الامتثال الرقابي: أي مخالفة للتعليمات والأطر الصادرة عن البنك المركزي السعودي أو نظام حماية البيانات الشخصية.
- انقطاع الخدمات الحيوية: التوقف غير المخطط له للقنوات المصرفية الرقمية بما يتجاوز اتفاقيات مستوى الخدمة (هدف توفر لا يقل عن 99.95% سنوياً).

عتبة قبول المخاطر: وفق مصفوفة تقييم المخاطر المعتمدة (5x5)، يعتبر أي خطر متبقي يتجاوز الدرجة 9 (متوسط) غير مقبول نهائياً، ويلزم تطبيق خطة معالجة فورية وضوابط تخفيفية معتمدة من مدير أمن المعلومات (CISO) ولجنة المخاطر التنفيذية.

4. الأطراف المعنية ومتطلباتها

يحدد هذا القسم من المستند الأطراف المعنية ذات الصلة بنظام إدارة أمن المعلومات (ISMS) ومتطلباتها، كما يلخص المتطلبات القانونية والتنظيمية المعمول بها والتي تلتزم بها المنظمة.

4.1 قائمة الأطراف المعنية

تشمل الأطراف المعنية الرئيسية ذات الصلة بال-ISMS:

- الجهات التشريعية والرقابية: البنك المركزي السعودي (ساما)، هيئة البيانات والذكاء الاصطناعي (سدايا)، الهيئة الوطنية للأمن السيبراني (NCA)، والجهات القضائية والأمنية.
- عملاء البنك: أكثر من 500,000 عميل من قطاعي الأفراد والشركات.
- الإدارة وحملة الأسهم: مجلس الإدارة، الإدارة التنفيذية العليا، والمساهمون.
- منسوبو البنك: 2,500 موظف دائم ومؤقت، والمتعاقدون، والموظفون المتقاعدون والسابقون.
- المؤسسات المالية والشبكات الدولية: شبكة سويفت الدولية، البنوك المراسلة، وشبكة المدفوعات الوطنية (مدى وسريع).
- الشركاء التقنيون والموردون: مزودو السحابة (AWS)، شركات الاتصالات (STC)، مطورو البرمجيات، وشركات صيانة الصرافات الآلية.

4.2 مصفوفة المتطلبات والضوابط المقابلة

يلخص الجدول رقم 1 أدناه متطلبات الأطراف المعنية الأساسية وكيفية معالجتها وتلبيتها عبر ضوابط الـ ISMS:

الطرف المعني	المرجع	ملخص المتطلبات والاحتياجات	هل تمت معالجة المطلب عبر الـ ISMS؟ وكيف؟
البنك المركزي السعودي (ساما)	R1	تطبيق إطار شامل للأمن السيبراني؛ إبلاغ فوري عن الحوادث الكبرى؛ فحص دوري للثغرات واختبارات اختراق؛ وتوفير خطط استمرارية أعمال معتمدة ومختبرة.	نعم، تمت معالجته عبر البنود 4 إلى 10، والضوابط A.5.31 (المتطلبات التشريعية)، A.5.24-A.5.28 (إدارة الحوادث)، A.5.30 (استمرارية تقنية المعلومات)، و A.8.8 (إدارة الثغرات).
هيئة البيانات والذكاء الاصطناعي (سدایا)	R2	الامتثال التام لنظام حماية البيانات الشخصية؛ توفير موافقات جمع البيانات؛ تمكين العملاء من حقوقهم في الاطلاع والتصحيح والحذف؛ وإجراء تقييم أثر حماية البيانات (DPIA).	نعم، تمت معالجته بالضابط A.5.34 (حماية الخصوصية ومعلومات التعريف الشخصية PII)، والضابط A.8.10 (حذف المعلومات الآمن).
عملاء البنك (أفراد وشركات)	R3	حماية سرية الحسابات؛ توافر مستمر للفتواتر الرقمية دون انقطاع؛ إشعار فوري بالحوادث أو العمليات المشبوهة؛ وحماية الأرصدة من الاحتيال.	نعم، تمت تلبيته عبر ضوابط التشفير A.8.24، وأمن الشبكات A.8.20، وضوابط استمرارية الأعمال A.5.29 و A.5.30.
مجلس الإدارة والمساهمون	R4	حماية سمعة البنك ومكانته السوقية؛ تجنب الغرامات التنظيمية؛ وضمان استدامة الربحية وحماية قيمة استثمارات المساهمين.	نعم، تمت معالجته بالبند 5.1 (القيادة والالتزام)، والبند 6.1 (إدارة المخاطر)، والبند 9.3 (مراجعة الإدارة الدورية).
الإدارة التنفيذية (CEO/CIO/CISO)	R5	تقارير دورية ومؤشرات واضحة (KPIs) لفعالية الأمن السيبراني؛ عدم إعاقة العمليات المصرفية؛ ومواءمة الأمن مع الأهداف الاستراتيجية للبنك.	نعم، تمت صياغته في البند 6.2 (أهداف أمن المعلومات)، والبند 9.1 (المراقبة والقياس والتقييم).
موظفو البنك (2,500 موظف)	R6	حماية ملفاتهم الشخصية وسجلات رواتبهم؛ وضوح سياسات الاستخدام المقبول؛ بيئة عمل تقنية آمنة؛ وتوفير توعية دورية واضحة.	نعم، عبر الضابط A.5.10 (الاستخدام المقبول للأصول)، والضوابط A.6.1 إلى A.6.8 (أمن الموارد البشرية)، و A.6.7 (العمل عن بعد).
البنوك المراسلة ومنظمة سويقت	R7	الامتثال لمتطلبات برنامج أمن العملاء (SWIFT CSP)؛ وسلامة وموثوقية قنوات التحويلات المالية الدولية عبر الحدود.	نعم، عبر الضابط A.5.14 (نقل المعلومات)، والضابط A.8.5 (المصادقة الآمنة)، وضوابط التشفير A.8.24.
مزود الخدمات السحابية (AWS)	R8	وضوح متطلبات الأمن ومسؤوليات البنك؛ والالتزام بسياسة الاستخدام المقبول والنموذج المشترك للمسؤولية السحابية.	نعم، عبر الضابط A.5.23 (أمن المعلومات لاستخدام خدمات الحوسبة السحابية)، و A.5.19 (أمن العلاقات مع الموردين).
شركات تطوير التطبيقات والبرمجيات	R9	متطلبات واضحة للتطوير الآمن؛ حماية حقوق الملكية الفكرية؛ توفير بيانات اختبار معزولة؛ وعدم استخدام بيانات إنتاج حقيقية في الاختبار.	نعم، عبر الضوابط A.8.25 إلى A.8.33 (دورة حياة التطوير الآمن وفصل البيانات)، و A.5.32 (حقوق الملكية الفكرية).
إدارة المراجعة الداخلية	R10	قابلية النظام للتدقيق بشكل كامل وموثق؛ توفير مسارات تدقيق واضحة؛ ومتابعة تصحيح حالات عدم المطابقة.	نعم، عبر البند 9.2 (التدقيق الداخلي المستقل)، والبند 10.2 (عدم المطابقة والإجراءات التصحيحية).

5. الغرض ونطاق نظام إدارة أمن المعلومات

5.1 الغرض

يتمثل الغرض من نظام إدارة أمن المعلومات (ISMS) في:

1. فهم احتياجات المنظمة وضرورة وضع سياسة وأهداف إدارة أمن المعلومات.
2. تطبيق وتشغيل الضوابط والتدابير الرقابية لإدارة القدرة الكلية للمنظمة على التعامل مع حوادث أمن المعلومات.
3. مراقبة ومراجعة أداء وفعالية نظام إدارة أمن المعلومات.
4. التحسين المستمر لأمن المعلومات في المنظمة استناداً إلى قياسات موضوعية.

ينطبق هذا الغرض على نطاق نظام إدارة أمن المعلومات كما هو محدد أدناه.

5.2 الآثار المحتملة لحوادث أمن المعلومات

يعتمد الأثر المترتب على أي حادث محدد بطبيعة الحال على طبيعته، ويتم الاحتفاظ بتقييم شامل للمخاطر وتحديثه باستمرار لتقييم وتخفيف آثار المخاطر التي يمكن تحديدها بصورة معقولة. وبشكل عام، سيظهر الأثر المحتمل لعدم القدرة على تنفيذ إجراءات العمل المعتادة في واحد أو أكثر من المجالات الرئيسية التالية:

- خسائر مالية مباشرة: خسائر الاحتيال المالي، تكاليف التحقيقات الجنائية، وفدية الهجمات، إضافة إلى الغرامات الصارمة من البنك المركزي وسدايا.
- أضرار جسيمة بالسمعة: فقدان ثقة المودعين والعملاء، تداول التحذيرات على وسائل التواصل الاجتماعي، وهجرة العملاء للبنوك المنافسة (كما حدث جزئياً في أزمة شهادة SSL).
- شلل العمليات المصرفية: توقف صرف رواتب آلاف الموظفين (كما كادت تتسبب به حادثة جدار الحماية)، وتعطل شبكات نقاط البيع وأجهزة الصراف الآلي.
- عقوبات تنظيمية وقانونية: فرض غرامات مليونية، تعليق رخصة تقديم الخدمات الرقمية، والمساءلة القضائية والجنائية لمسؤولي البنك بموجب نظام مكافحة الجرائم المعلوماتية.

5.3 أهداف أمن المعلومات المحددة (SMART)

استناداً إلى المتطلبات والقضايا الموضحة في هذا المستند، تم تحديد الأهداف الرئيسية التالية لأمن المعلومات:

- الهدف الأول (تعزيز المناعة ضد الهندسة الاجتماعية): خفض نسبة الموظفين المتجاوبين مع رسائل التصيد الوهمية من 25% إلى أقل من 3%، وزيادة نسبة الإبلاغ من 8% إلى أكثر من 75% خلال 6 أشهر عبر برامج توعية مكثفة ومحاكاة دورية.
- الهدف الثاني (تحسين التطبيقات المصرفية الرقمية): إغلاق ومعالجة 100% من الثغرات الحرجة والعالية المكتشفة في تطبيق 'آفاق بلس' ومنصة 'آفاق نت' خلال 14 يوماً من اكتشافها، وأتمتة فحص الأمان البرمجي (SAST/DAST) في GitLab.
- الهدف الثالث (استمرارية وتوافر الخدمات الرقمية): ضمان تحقيق نسبة توفر لا تقل عن 99.95% للخدمات المصرفية الرقمية، مع فرض مبدأ الرقابة الثنائية (Four-Eyes Principle) وخطط التراجع التلقائية على جميع تعديلات جدران الحماية والشبكات.
- الهدف الرابع (التشفير الشامل وإدارة الشهادات الرقمية): فرض التشفير الكامل للأقراص (BitLocker) بنسبة 100% على كافة أجهزة الحواسيب المحمولة للموظفين (2,000 جهاز) خلال 60 يوماً، وتفعيل نظام آلي لمراقبة وتجديد شهادات SSL/TLS قبل 30 يوماً من انتهائها.

سيتم الحكم على نجاح نظام إدارة أمن المعلومات بناءً على قدرته على تحقيق هذه الأهداف العامة.

5.4 نطاق نظام إدارة أمن المعلومات

يراعي النطاق المحدد لنظام إدارة أمن المعلومات (ISMS) التابع لبنك الأفاق الرقمية القضايا الداخلية والخارجية المشار إليها في القسمين 3.1 و 3.2 من هذا المستند، بالإضافة إلى المتطلبات المشار إليها في القسم 4. كما يعكس احتياجات الأطراف المعنية والمتطلبات القانونية والتنظيمية المعمول بها والمطبقة على المنظمة.

تم تحديد النطاق أدناه من حيث قطاعات المنظمة، ومنتجاتها وخدماتها، والأنشطة المرتبطة بها.

5.4.1 النطاق التنظيمي

يشمل نظام إدارة أمن المعلومات (ISMS) الأجزاء والقطاعات التالية من بنك الأفاق:

- قطاع التقنية والأمن: قطاع التقنية والعمليات بكافة أقسامه (البنية التحتية، التطبيقات، التطوير، قواعد البيانات، والدعم الفني) وإدارة أمن المعلومات (الحوكمة، SOC، الاستجابة للحوادث، وإدارة المخاطر).
- قطاع الحوكمة والمخاطر: الإدارة العليا، إدارة المخاطر المؤسسية، الالتزام والحوكمة، الشؤون القانونية، والمراجعة الداخلية.
- قطاع الأعمال والعمليات المصرفية: الخدمات المصرفية للأفراد، الخدمات المصرفية للشركات، الخزينة والاستثمار، والعمليات المصرفية الدولية.
- القطاعات المساندة الحاوية لبيانات PII: الموارد البشرية (شؤون الموظفين، التوظيف، التدريب) والإدارة المالية وإدارة الرواتب والمزايا.
- المواقع الفيزيائية: المقر الرئيسي بالرياض (حي المال والأعمال - مبنى الـ 12 طابقاً بالكامل)، مركز البيانات الرئيسي (الطابق الثالث)، مركز التعافي من الكوارث (المنطقة الصناعية بجدة)، شبكة الفروع المصرفية (25 فرعاً)، و 75 جهاز صراف آلي مستقل.

5.4.2 المنتجات والخدمات

تقع المنتجات والخدمات التالية ضمن نطاق نظام إدارة أمن المعلومات (ISMS) :

- تطبيق الهاتف المحمول المصرفي 'أفاق بلس' (منصتا iOS و Android).
- بوابة الخدمات المصرفية عبر الإنترنت 'أفاق نت' (للأفراد والشركات).
- نظام العمليات المصرفية الأساسي (Core Banking System) لإدارة الحسابات والودائع والقروض.
- نظام إدارة البطاقات (CMS) لمعالجة بطاقات الصراف الآلي والائتمان ومكافحة الاحتيال.
- نظام الدفعات الفورية (IPS) المتصل بشبكة المدفوعات الوطنية (سريع).
- شبكة سويفت الدولية لرسائل الحوالات الخارجية وتسويات الخزينة.
- قنوات فتح الحسابات الرقمية والتحقق من الهوية (e-KYC) وإدارة ملفات العملاء.

5.4.3 الأنشطة

تقع الأنشطة التالية ضمن نطاق نظام إدارة أمن المعلومات (ISMS) :

- تطوير وبرمجة التطبيقات، فحص الكود، إدارة مستودعات GitLab، وإدارة بيانات النشر.
- إدارة قواعد بيانات Oracle و SQL Server، ومزامنة النسخ المتماثلة إلى موقع جدة، وإدارة مفاتيح التشفير.
- إدارة جدران الحماية Palo Alto، وجدران حماية تطبيقات الويب Fortinet FortiWeb، وأجهزة التوجيه Cisco.
- المراقبة الأمنية والتحليل الأمني على مدار 7/24 عبر الـ SOC، والاستجابة للحوادث السيبرانية.
- إدارة الهويات وحسابات الدليل النشط (Active Directory) وإدارة الصلاحيات والتحقق متعدد العوامل.
- إدارة عمليات النسخ الاحتياطي عبر Veritas NetBackup وتجارب استمرارية الأعمال والتعافي من الكوارث.

5.4.4 الاستثناءات

تُستثنى المجالات التالية صراحةً من نطاق نظام إدارة أمن المعلومات (ISMS) :

- أعمال الصيانة العامة والنظافة للمرافق: أعمال الصيانة الميكانيكية للتكييف، السباكة، والنظافة العامة للمباني التي ينفذها مقاولو المرافق العامة مستثناة من ضوابط معالجة البيانات، لكونها لا تعالج ولا تطلع على معلومات مصرفية. التبرير والضابط البديل: يخضع عمال الصيانة والنظافة للضوابط الأمنية الفيزيائية الإلزامية (الملحق A.7) التي تشمل تسجيل الدخول، ارتداء الشارات الأمنية، والمرافقة المستمرة (Escort) داخل المناطق الحساسة ومراكز البيانات.
- آليات النقل اللوجستي لشركات نقل الأموال: حركة سيارات نقل الأموال المصفحة التابعة للشركات الأمنية الخارجية مستثناة من الإدارة التقنية المباشرة للبنك، لكونها مغطاة باتفاقيات تأمين تجاري منفصلة وتخضع للوائح الأمن والسلامة الفيزيائية الصادرة عن الجهات الأمنية والبنك المركزي؛ مع بقاء واجهات الربط وجدولة التغذية النقدية التابعة لأنظمة البنك ضمن نطاق الـ ISMS.